Table of Contents

Cisco Secure Workload — CISA Zero Trust Maturity Model

Reference Design | Federal & Enterprise Accounts

Version: 1.0 | **Standard:** CISA Zero Trust Maturity Model v2.0 (2023)

Reader's Guide

Who this is for. Federal civilian agencies executing on EO 14028 / OMB M-22-09, federal contractors with parallel obligations, enterprises that have adopted CISA's maturity model voluntarily.

Questions this reference design helps you answer:

- *Across the 5 ZTMM pillars (Identity, Devices, Networks, Applications & Workloads, Data), where am I today on the Traditional → Initial → Advanced → Optimal scale, and where is the evidence?*
- *What's the smallest set of changes that moves my Networks pillar and my Applications & Workloads pillar from Initial to Advanced?*
- *For OMB M-22-09 progress reporting, what artifacts can I produce on a quarterly basis without rerunning manual assessments?*
- *Reaching "Optimal" on a pillar implies continuous validation. What does that look like as a daily operational signal, not an annual audit one?*
- *Where do I depend on other Cisco portfolio products (Identity, Endpoint, Cloud, Data) to reach Optimal across all five pillars?*

What you'll need. Your current ZTMM self-assessment (or a willingness to do one), a prioritized list of pillars by business risk, and visibility into your existing IdP, EDR, and CSPM tooling.

Where to start. Sections 2–4 for pillar-by-pillar capability mapping; section 5 for the coverage summary across all pillars; sections 6–7 for the scope tree and the enforcement policy that move the Networks pillar to Advanced; section 8 for a phased deployment plan; section 10 if your team uses a scorecard format.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	**Live** network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement **operates**

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: Compliance evidence playbook (full step-by-step) · About CSW (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-	Days 11–28

Phase	Goal	Key CSW actions	Typical duration
		owner signoff	
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Networks + Applications/Workloads pillar progression with measurable maturity
- Observable enforce mode vs. monitor-only baseline
- Policy enforcement at workload as ZT PEP placement

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

---

1. Overview

The CISA Zero Trust Maturity Model (ZTMM) v2.0 defines maturity across **5 pillars**: Identity, Devices, Networks, Applications & Workloads, and Data. CSW is the primary Cisco platform addressing the **Networks** pillar and makes significant contributions to **Applications & Workloads** and **Data** pillars. Each pillar has 4 maturity stages: Traditional → Initial → Advanced → Optimal.

---

2. CSW Maturity Mapping — Networks Pillar (Primary)

The Networks pillar focuses on macro/micro-segmentation, encryption, and network traffic management.

Maturity Stage	Networks Pillar Requirement	CSW Capability
Traditional	Coarse perimeter-based segmentation	CSW ADM reveals actual traffic — baseline for improvement
Initial	Basic internal segmentation; some visibility	CSW ADM deployed; monitoring mode; scopes defined
Advanced	Micro-segmentation enforced; encrypted traffic	CSW enforcement active; allowlist policies; encryption detection
Optimal	Dynamic policy; continuous validation; full automation	CSW ADM continuous re-run; API-driven policy updates; ML anomaly detection

Achieving Advanced Maturity (Networks)

```
Phase 1 — Initial (Weeks 1-4):
  ✓ Deploy CSW sensors across all workloads
```

```
  ✓ Run ADM — document all traffic flows
  ✓ Define scope hierarchy (environment, sensitivity, function)
  ✓ Enable flow telemetry and alerting

Phase 2 — Advanced (Weeks 5-12):
  ✓ Build allowlist policies from ADM baseline
  ✓ Enable enforcement mode on sensitive scopes
  ✓ Detect and block unencrypted flows (HTTP, Telnet, FTP)
  ✓ Isolate workloads into least-privilege network segments
  ✓ Configure anomaly detection on production scopes

Phase 3 — Optimal (Ongoing):
  ✓ Continuous ADM re-runs (90-day cycles)
  ✓ API integration with SOAR for automated policy response
  ✓ ML-based behavioral baseline deviation detection
  ✓ Dynamic policy adjustment based on workload risk score
```

---

3. CSW Maturity Mapping — Applications & Workloads Pillar

Maturity Stage	Requirement	CSW capability that may support evidence toward the stage
Traditional	No workload-level visibility	ADM provides first-ever workload communication map
Initial	Basic application inventory; some access controls	CSW inventory + scope-based access policies
Advanced	Workload identity-based access; continuous monitoring	Process-level identity; policy enforcement; anomaly detection
Optimal	Automated workload security; continuous validation	API-driven policy; vulnerability-triggered policy updates

Key CSW Contributions:

- **Workload Identity:** CSW uses process hash, OS fingerprint, and network identity — not just IP
- **Least Privilege Workload Access:** Each workload allowed only its documented communication paths
- **Continuous Validation:** ADM re-runs validate workloads haven't expanded their access footprint
- **Vulnerability-Aware Policy:** Critical CVEs on a workload can trigger automatic policy tightening

4. CSW Maturity Mapping — Data Pillar (Supporting)

Maturity Stage	Requirement	CSW Capability
Traditional	No data flow visibility	ADM reveals observed data movement paths within CSW coverage
Initial	Data categorized; basic access controls	Scope-based isolation for sensitive data workloads
Advanced	Data access logged; encryption enforced	Full flow telemetry; encryption compliance enforcement
Optimal	Automated data protection response	Alert-triggered policy updates on data access violations

5. CISA ZTMM Pillar Coverage Summary

Pillar	CSW Role	Example maturity evidence CSW may support
Identity	Supporting (enforces identity-aware workload access paths where integrated)	Initial → Advanced evidence when paired with IAM / IdP controls
Devices	Supporting (process + OS-level workload fingerprinting)	Initial → Advanced evidence for covered workloads
Networks	**Primary** for workload micro-segmentation, plaintext-flow detection / blocking, monitoring	Advanced evidence; Optimal remains an organizational target
Applications & Workloads	**Primary** for workload identity, policy, vulnerability context	Advanced evidence; Optimal remains an organizational target
Data	Supporting (data flow visibility, plaintext-flow detection / blocking)	Initial → Advanced evidence when paired with data governance controls

6. Scope Architecture for ZTMM

Maturity is claimed per pillar, so the scope tree has to make a pillar claim provable for a named set of workloads. Build the tree before any enforcement work: the Networks and Applications pillars both move from Initial to Advanced on the strength of *which* workloads sit inside a deny-by-default boundary, not on the existence of policy in general.

6.1 Suggested Scope Architecture

```
Root Scope
└── Zero-Trust-Estate
    ├── High-Value-Assets                    (HVA register — OMB M-22-09
priority)
    │   ├── Mission-Applications
    │   └── Authoritative-Data-Stores
    ├── Enterprise-Applications
    │   ├── Public-Facing
    │   └── Internal-Facing
    ├── Identity-Infrastructure              (IdP, directory, PKI —
Identity pillar edge)
    ├── Security-Services                    (EDR, SIEM, scanners, CSPM)
    ├── Privileged-Access-Paths              (bastions / jump hosts)
    └── Untrusted
        ├── Internet-Edge
        └── Partner-Connectivity
```

The `Untrusted` branch matters more here than in a compliance-boundary design: ZTMM treats the network as hostile by default, so the tree should name the untrusted side explicitly rather than leave it as the implicit remainder.

6.2 Inventory Filters

```
Filter: High-Value-Assets
  - Tag: hva = true
  - Tag: fisma_impact = high | moderate
  - Hostname / application pattern matches the HVA register

Filter: Authoritative-Data-Stores
  - Tag: data_category = authoritative | sensitive
  - Listening port: 1433, 1521, 3306, 5432, 27017

Filter: Identity-Infrastructure
  - Listening port: 88, 389, 636, 3268, 1812
  - Tag: application = idp | directory | pki

Filter: Partner-Connectivity
  - Destination outside agency on-prem and cloud allow-lists
  - Tag: managed_by = partner | contractor
```

6.3 Labeling Strategy

Label key	Example values	Why it matters for ZTMM
`zt_pillar`	networks, applications, data, identity, devices	Routes each workload's evidence to the right pillar in the section 10 scorecard
`zt_stage`	traditional, initial, advanced, optimal	Records the stage actually claimed per workload, so the scorecard is defensible per-asset rather than per-agency
`hva`	true, false	Sequences Advanced/Optimal work onto OMB M-22-09 high-value assets first
`data_category`	authoritative, sensitive, internal, public	Data pillar isolation and plaintext-flow findings
`fisma_impact`	high, moderate, low	Aligns enforcement stringency to the FIPS 199 categorisation
`application`		Connects workloads to the systems named in the ZTMM self-assessment
`owner`		Accountability
`compliance`	cisa-ztmm	Filters CSW evidence to the ZTMM assessment boundary

`zt_stage` is the label that makes quarterly OMB M-22-09 reporting cheap. Without it, every reporting cycle restates the agency's maturity from memory; with it, the stage claim is a queryable property of the inventory.

---

7. Policy Design — Networks & Workloads Enforcement

7.1 ZTMM-Aligned Policy Framework

Absolute policies:

```
DENY  Any                          → High-Value-Assets
(default deny inbound)
DENY  High-Value-Assets            → Internet                    (no
```

```
direct internet egress from HVAs)
DENY  Untrusted                  → Enterprise-Applications     (no
direct untrusted-to-workload path)
DENY  Enterprise-Applications    → Enterprise-Applications     (no
implicit east-west inside the tier)
```

The fourth rule is the one that separates Initial from Advanced on the Networks pillar. Perimeter-shaped policy denies north-south and leaves east-west implicit; ZTMM Advanced expects the inverse.

Allowlist policies (least privilege):

```
ALLOW Internet-Edge              → Public-Facing              tcp/443
ALLOW Public-Facing              → Internal-Facing            tcp/443
ALLOW Internal-Facing            → Authoritative-Data-Stores
tcp/<db-port-tls>
ALLOW Mission-Applications       → Identity-Infrastructure
tcp/636, tcp/88
ALLOW Privileged-Access-Paths    → High-Value-Assets          tcp/22,
tcp/3389
ALLOW Zero-Trust-Estate          → Security-Services          tcp/443
```

Catch-all:

```
LOG   Any                        → High-Value-Assets
(unmatched inbound)
LOG   High-Value-Assets          → Any
(unmatched outbound)
LOG   Zero-Trust-Estate          → Any
(plaintext: tcp/80, tcp/21, tcp/23, tcp/389, udp/161)
```

The plaintext catch-all is the detection input for the Networks pillar encryption expectation. Treat it as a finding generator first; convert those rows to `DENY` only once the application owners have a TLS path.

7.2 Policy Workspace Lifecycle

Phase	Mode	Duration	Purpose
1	Simulation	2 weeks	Validate the candidate policy
2	Enforcement (high-confidence rules only)	1 week	Enforce obvious deny rules
3	Full Enforcement	Ongoing	Workload allowlist enforced; monthly exception review

7.3 Enforcement State to Networks Pillar Stage

The maturity claim should follow the workspace state, not the project plan. Use this to keep the section 10 scorecard honest:

Workspace state	Networks pillar stage	Evidence to retain
ADM running, no workspace	Traditional	ADM baseline export
Workspace in Simulation	Initial	Policy export + simulation report
Enforcement on HVA scopes, deny-by-default inbound	Advanced	Policy export + Denied Connections sample
Enforcement estate-wide, east-west denied by default, 90-day ADM re-run closing the loop	Optimal	Re-run comparison + API audit log

Workspace snapshots and the Denied Connections log are the two artifacts an assessor will ask for when the agency claims Advanced or better.

---

8. CSW Deployment Phases for ZTMM

Phase 1 — Establish Visibility (Traditional → Initial)

```
Week 1-2:   Deploy sensors (on-prem + cloud connectors)
Week 3-4:   Run ADM — generate traffic baseline
Week 4:     Define scope hierarchy
Week 4:     Enable flow telemetry retention (12 months)
```

Phase 2 — Enforce Least Privilege (Initial → Advanced)

```
Week 5-6:   Build allowlist policies from ADM
Week 7-8:   Simulation mode — validate no false positives
Week 9-10:  Enforcement mode — sensitive scopes first
Week 11-12: Encryption enforcement; block non-compliant protocols
Week 12:    Full alerting and SIEM integration
```

Phase 3 — Continuous Validation (Advanced → Optimal)

```
Month 4+:   90-day ADM re-run cycles
Month 4+:   Vulnerability-triggered policy review
Month 6+:   API integration with SOAR
Month 6+:   Automated policy tightening on critical CVEs
Ongoing:    Maturity assessment vs ZTMM scorecard
```

---

9. ZTMM Assessment Evidence Package

Evidence Item	CSW Source	ZTMM Pillar	Maturity Stage
ADM traffic baseline	Investigate → ADM	Networks, Apps	Initial
Enforcement policy export	Defend → Policy Workspaces	Networks, Apps	Advanced
Encryption compliance report	Flow Search (protocol filter)	Networks, Data	Advanced
Anomaly detection log	Alerts → Dashboard	Networks	Advanced
Vulnerability report	Investigate → Vulnerability	Apps	Advanced
Continuous ADM comparison	ADM re-run vs baseline	Networks, Apps	Optimal
API policy automation evidence	CSW API audit log	Networks	Optimal
Workload inventory	Manage → Inventory	Devices, Apps	Initial

10. ZTMM Scorecard Template

Pillar	Current Stage	Target Stage	CSW Actions Required
Identity	Traditional	Advanced	Enforce identity-verified access paths via CSW
Devices	Initial	Advanced	Process-level workload fingerprinting; anomaly detection
Networks	Initial	Optimal	Full enforcement; encryption; continuous ADM
Applications	Traditional	Advanced	Workload-level policy; vulnerability management
Data	Traditional	Advanced	Data flow visibility; encryption

Pillar	Current Stage	Target Stage	CSW Actions Required
			enforcement

Related Frameworks

- NIST SP 800-207 — ZTA Seven Tenets — the architectural foundation underneath the maturity model.
- NIST SP 800-207A — PDP/PEP/PA/PIP — the logical-component view that aligns with the ZTMM "Optimal" tier.
- NIST SP 800-53 Rev 5 — when CISA ZTMM is being mapped to a federal control baseline.

Replace [Customer Name] and bracketed fields before customer delivery.